INTERNAL DEVELOPMENT PILOT • GOOGLE CLOUD • GSK EXCLUDED

AI SRE Copilot

Dev Pilot

A controlled, evidence-linked AI diagnosis service with deterministic policy validation and mandatory human approval — built entirely in QI's internal GCP project. No GSK data, credentials, or environments.

4–6 WEEKS | ≤ 20 Cloud Run services | USD 250 ceiling | Human-in-the-loop | Zero-trust IAM

ENVIRONMENT	Quantum Integrators internal GCP project • us-east1 / us-central1
PILOT COORDINATOR	Gupteswar Mishra
TECHNICAL LEAD	Akshay Saxena
SPONSORS / APPROVERS	Ken / Prithiviraj — Business & Budget Authority
DATE & VERSION	16 October 2026 • v2.0 — Tier-1 Enhanced Edition (supersedes v1.0)
CLASSIFICATION	Confidential — QI Internal • Not for external distribution

DECISION REQUESTED ● Conditional Approval

ASK	BUDGET CEILING
Approve	**USD 250**
QI-only pilot subject to gates	Pending period validation
SCOPE	**RISK POSTURE**
≤ 20 services	**Guardrailed**
Start with 2, scale on evidence	Recommend-only • Approval-bound

■ **Go / No-Go Rule:** Privileged remediation stays disabled until IAM isolation, approval-binding, and all negative bypass tests pass. This pilot does not certify production readiness and does not authorize any GSK implementation.

CONTENTS

Enhanced Proposal — Tier-1 Edition

This enhanced edition restructures the original 7-page working draft into a board-ready, audit-defensible pilot charter. Substance preserved; structure, rigor, and assurance elevated to Tier-1 consulting standards.

0	Executive Summary — One-page decision brief	3
1	Strategic Context — Situation & Imperative	4
2	Vision, Objectives & Outcomes — What success looks like	4
3	Scope & Boundaries — In / Out & Stage Gates	5
4	Target Architecture — Evidence-linked, policy-gated, workflow-executed	6
5	Security, IAM & Responsible AI — Zero-trust, least-privilege	7
6	Human Approval & Privileged Execution — Adversarial testing	8
7	Delivery Plan & Milestones — Stage-gated 4–6 weeks	9
8	Financial Model & Budget — USD 250 ceiling & unit economics	10
9	Success Measures & Acceptance — Audited KPIs	11
10	Risks, Assumptions, Issues & Dependencies — RAID	12
11	Governance & Operating Model — RACI & Cadence	13
12	Decisions Requested & Next Steps — What we need this week	14
A	Appendices — References, schemas, assumptions, scenarios	15

How to use this document
Executives: Cover + §0 + §12. **Engineering & Security:** §4–§6. **Finance & Platform:** §8. **All reviewers:** §9–§11. Print-friendly A4; page breaks optimized.

AT A GLANCE	DESIGN AXIOM
5 scenarios **≥10** scored runs **100%** approval-bound **0** autonomous IAM/DB	AI proposes → deterministic policy validates → authorized human approves → protected workflow executes → health checks verify → audit records persist.

CONFIDENTIAL — QI INTERNAL DEVELOPMENT PILOT — GSK IMPLEMENTATION, DATA, AND CREDENTIALS EXPLICITLY EXCLUDED

EXECUTIVE SUMMARY — ONE-PAGE DECISION BRIEF

0 The ask, the why, and the conditions

Situation: SRE toil is dominated by alert triage, log correlation, and runbook lookup — slow, inconsistent, and audit-heavy. **Complication:** Naïve AI automation risks prompt injection, privilege creep, and unapproved changes. **Question:** Can we prove, in a safe QI sandbox, that an AI-assisted copilot *accelerates diagnosis* without weakening change control?

Answer (pilot thesis): Yes — *if* we enforce a hard separation: **AI proposes → deterministic policy validates → human approves → protected workflow executes → health checks verify → audit records persist**. The copilot never holds deployment credentials; the deployer never sees raw prompts.

RECOMMENDATION

Conditionally approve the QI dev pilot. Release privileged remediation *only after* all negative tests pass.

Why now

- Grafana CE + Cloud Monitoring mature for bounded evidence
- Vertex AI Gemini gives structured, citation-linked output
- Workload Identity Federation enables short-lived, narrow creds
- Existing GitHub Actions can enforce approval binding today

What we will prove in 4–6 weeks

- ≥90% correct primary diagnosis across ≥10 scored runs
- Zero changes outside approved workflows
- 100% approval coverage for privileged actions
- Median alert→approved-fix time vs. manual baseline

What we will NOT do

- No GSK env, creds, or data — ever in this pilot
- No autonomous IAM / DB / quota / failover changes
- No execution of arbitrary model-generated commands
- No claim of production certification

Value hypothesis (to be measured, not assumed)
Industry SRE studies show 30–50% of MTTR is spent on correlation & runbook lookup. If the copilot cuts that slice by half, a 20–25% MTTR reduction is plausible on in-scope incidents — **without** increasing change risk, because every privileged action remains human-approved and audit-recorded. The pilot will quantify this against a manual baseline agreed at kickoff.

Condition	Gate & Evidence	Owner
Written scope & budget approval	Signed decision log confirming USD 250 period (full pilot vs. monthly) + contingency rule	Ken / Prithiviraj
Named owners & approvers	RACI confirmed; ≥2 authorized approvers in GitHub protected environment	Gupteswar
Access readiness	GCP project, billing, IAM, GitHub plan/branch protection & WIF trust validated	Cloud Platform
Approval controls verified	All bypass tests pass (see §6); remediation stays disabled until then	CI/CD + Security
Security review	Data-handling, redaction, log-as-untrusted-input, retention reviewed	Security Reviewer

Confidentiality & Scope Boundary — Read First
This pilot is **QI-internal only**. It does not authorize access to, deployment in, or use of credentials or data from GSK. Any future GSK implementation requires a separate architecture, security, access, budget, and go-live approval package.

1 STRATEGIC CONTEXT

Situation & Imperative — Why this pilot, why now

Market & technology tailwinds

Observability (Cloud Monitoring + Grafana) and LLMs (Vertex AI Gemini) have converged to make *evidence-linked diagnosis* feasible. Workload Identity Federation removes the need for long-lived keys. Together they allow a **recommendation-first** copilot that is both useful and controllable — a materially better trade-off than 12 months ago.

QI-specific opportunity

QI runs lean, multi-region Cloud Run estates. SRE load is bursty. A copilot that correlates alerts, pulls bounded evidence, and surfaces runbook-backed next steps — **inside QI's own project** — builds reusable IP before any client conversation. This pilot is an **internal capability bet**, not a client delivery commitment.

Guiding Principles — Non-negotiables

1 Human-in-command
AI recommends; humans decide; workflows execute.

2 Least privilege by design
No identity holds more access than its job requires.

3 Untrusted model output
Every proposal is schema-validated and allowlist-checked.

4 Auditability first
If it isn't recorded, it didn't happen.

5 Fail safe, fail closed
Approval unavailable → remediation disabled.

6 Progressive exposure
2 services → measure → then scale to ≤20.

2 VISION, OBJECTIVES & OUTCOMES

What success looks like

#	Objective (Outcome)	Key Result (Measurable)	Evidence
O1	Detect representative incidents early	Grafana alerts + SLOs firing on all 5 scenarios within SLO window	Dashboard + alert history
O2	Correlate & collect bounded evidence	Per incident: alert graph, log slice, deploy metadata & runbook link	Incident evidence bundle
O3	Generate evidence-linked diagnosis	≥90% correct primary diagnosis across ≥10 scored runs (see §9)	Scored test log
O4	Route via approved CI/CD only	Zero infra changes outside protected GitHub workflows	Workflow audit trail
O5	Enforce human approval	100% of privileged remediations have pre-execution approval	Approval record
O6	Prove auditability & time value	Full trace (evidence→recommendation→decision →outcome) + median alert-to-fix vs. baseline	Audit log + timing report

✓ **Definition of Done for the pilot**
A pilot is **done** when all five scenarios have been exercised, at least ten runs are scored and traceable, all approval-bypass negative tests pass, spend is reconciled, and a **Proceed / Extend with Conditions / Stop** recommendation is presented at the Week-6 review. Demo is live, not slideware.

3 SCOPE & BOUNDARIES

In scope, out of scope, and stage gates

✓ In Scope
- Up to 10–20 lightweight Cloud Run services across *us-east1* & *us-central1* (start with 2, scale on cost signal)
- Grafana Community Edition dashboards, alerts & representative SLOs
- Authenticated incident intake, deduplication & correlation
- Bounded AI diagnosis with Vertex AI Gemini + approved runbooks (synthetic / QI-approved data only)
- Predefined CI/CD allowlist actions with mandatory approval & health checks
- **Five controlled fault scenarios:** bad deployment, crash loop / startup failure, quota exhaustion, disabled API, configuration drift
- ≥10 scored runs + negative tests (approval rejection, duplicate delivery, invalid model output, workflow failure)

✕ Out of Scope — Explicitly Excluded
- Any GSK environment access, credential use, data processing, or deployment
- Autonomous infra changes or direct execution of arbitrary AI-generated commands
- Automated IAM changes, database operations, regional failover, quota increases
- Production rollout, production-readiness certification, or implied GSK authorization
- New paid GitHub / SaaS subscriptions unless separately approved
- Broad Data Access audit logging before cost validation

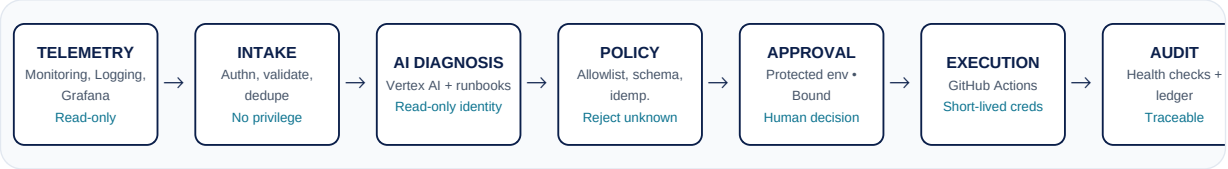
Allow-listed Actions Only (pilot)

✓ Rollback to previous revision ✓ Redeploy approved revision ✓ Restart / scale within bounds ✓ Toggle feature flag (pre-approved)
✕ IAM changes ✕ DB writes / migrations ✕ Quota increase ✕ Regional failover ✕ Arbitrary shell/commands

4 TARGET ARCHITECTURE

Evidence-linked, policy-gated, workflow-executed

Design axiom: *AI proposes; deterministic policy validates; authorized human approves; protected workflow executes; automated checks and audit records verify the outcome.* No step can be bypassed; each has a distinct identity and minimal scope.



QI boundary • Privileged creds never available to AI job; only to protected execution job post-approval • Telemetry treated as untrusted input

Layer	Responsibilities	Security Boundary	Failure Mode → Behavior
Telemetry	Metrics, logs, audit logs, Grafana dashboards & SLOs	Read-only; approved sources only	Source down → alert on intake health
Incident Intake	Authn, payload validation, dedupe, correlation	No privileged execution perms	Invalid payload → reject, no incident
AI Diagnosis	Bounded evidence + runbooks → Vertex AI → structured proposal	Read-only identity; no infra write	Malformed output → schema reject
Policy Validation	Allowlist, param bounds, scope, idempotency	Model output = untrusted input	Unknown action → reject
Approval	Present exact proposal to authorized reviewers	Bound to incident+proposal hash	Stale/changed → approval invalidated
Execution	Invoke predefined protected workflow	Short-lived, narrow IAM	Duplicate dispatch → idempotency blocks
Validation & Audit	Health checks; full ledger (evidence→outcome)	Immutable record; retention-limited	Inconclusive → escalate

Technology Stack (pilot)
- Compute: Cloud Run (scale-to-zero)
- Observability: Cloud Monitoring, Logging, Audit Logs, Grafana CE
- AI: Vertex AI — Gemini (structured, token-bounded, runbook-augmented)
- CI/CD: GitHub Actions + Protected Environments
- Identity: Workload Identity Federation (short-lived), Artifact Registry

Data & Evidence Bounds
- Per-incident token & log-volume budgets; strict truncation & redaction
- Secrets / PII redacted *before* model invocation
- Only synthetic or QI-approved data — no production PII
- Logs & runbooks treated as untrusted — prompt-injection hardened
- Request limits, timeouts, schema validation, safe fallback

5 SECURITY, IAM & RESPONSIBLE AI

Zero-trust, least-privilege, audit-first

■ **Security thesis**
Usefulness without trust expansion. The AI is the *least privileged* actor in the system. Privilege is concentrated in a single, audited approval-gated workflow — and is unavailable everywhere else.

Identity Separation — Minimum Necessary Access

Identity	Can Do (Allow)	Cannot Do (Deny) — Enforced	Test
Telemetry Collector	Read approved metrics, logs, service metadata	No deployment, no IAM writes, no secret access	Negative IAM probe
AI Diagnosis Service	Invoke Vertex AI; read selected evidence & runbooks	No infra modification, no workflow execution	Negative IAM probe
Incident Intake	Authenticate, validate, record incident events	No privileged GCP access	Authn bypass test
Workflow Dispatcher	Invoke *only* the approved workflow via WIF	No broad admin roles; no direct mutation	Scope test

Identity	Can Do (Allow)	Cannot Do (Deny) — Enforced	Test
Remediation Executor	Approved action on designated QI resources only	No Owner/Editor; no GSK; no cross-project	Negative IAM + scope
Human Approver	Approve/reject via protected environment	No implicit authority from model output	Bypass test

Mandatory Security Controls — Checklist (preflight)

Identity & Access
- WIF with short-lived creds; **no long-lived SA keys**
- Federation trust restricted to QI org / repo / branch / env / workflow
- Narrow roles + SA impersonation only where required
- Privileged creds only in protected job post-approval

Data & AI Safety
- Redact secrets *before* model call; synthetic / QI-approved data only
- Treat logs & runbooks as **untrusted input**
- No prompt content can alter policy or invoke tools
- Token budgets, timeouts, schema validation, safe failure

Platform Hardening
- Grafana + intake: authn/authz, restricted network, rate limits
- Audit logging enabled (cost-assessed); retention limits
- Artifact & secret storage scoped to executor only
- Branch + environment protection on GitHub

Cost & Abuse Controls
- Request limits, concurrency caps, token budgets
- Budget alerts at 50/75/90/100% — *notify*, not hard caps
- Daily spend review during fault-testing
- Idempotency + deduplication

Responsible AI guardrails
Every recommendation must include: **evidence citations, confidence, risk, validation result, and rollback plan**. Low-confidence or uncited proposals are auto-rejected by policy. Human reviewers are shown the *exact* bounded evidence the model saw — no hidden context.

6 HUMAN APPROVAL & PRIVILEGED EXECUTION

Approval-bound by design, tested by adversarial cases

1 • Propose Incident ID, target, action, revision, evidence, risk & rollback
2 • Validate Deterministic allowlist: schema, scope, params
3 • Protect Protected env: required reviewers + branch restrictions
4 • Bind Approval bound to hash; change → re-approval
5 • Isolate Privileged creds only to protected job
6 • Dedupe Idempotency keys + concurrency
7 • Verify Health checks; record outcome; escalate on fail

Approval Bypass — Adversarial Test Matrix (must all pass before remediation is enabled)

Adversarial Test	Expected Result	Evidence	Gate
No approval / rejected approval → dispatch	No infra change	Workflow logs + resource state	Blocking
Expired / cancelled approval → replay	No infra change	Approval validity check	Blocking
Proposal mutated post-approval	Approval invalidated — re-approval required	Hash comparison	Blocking
Duplicate incident / repeated dispatch	No duplicate remediation	Idempotency + concurrency log	Blocking
Unauthorized branch / actor → invoke	Cannot obtain privileged creds	WIF trust + branch protection	Blocking
Workflow rerun with stale approval	Fresh validity checks required	Rerun audit	Blocking
Approval controls unavailable	Remediation remains disabled	Fail-closed log	Blocking
Model proposes allowlist violation	Rejected by policy — no approval surface	Policy validation log	Blocking

Go / No-Go Rule — Non-negotiable
Privileged remediation remains **disabled** until every applicable bypass test demonstrates enforcement. The pilot coordinator + security reviewer must jointly sign the gate. No exceptions, no “temporarily allow”.

Rollback discipline
Post-action health checks run automatically. **Failed or inconclusive recovery is escalated**; rollback follows a *separately authorized* path — never an auto-rollback triggered by model output. Rollback proposals are themselves subject to approval binding.

GitHub protections (to be confirmed at readiness gate)
Protected environment with **required reviewers**, branch restrictions, and environment-scoped secrets. Verify QI repo plan supports required protections; if not, document limitation and alternate compensating control before Week-1.

7 DELIVERY PLAN & MILESTONES

Stage-gated, 4–6 weeks, exit criteria at every gate

Phase 0 — Approval & Readiness Before Week 1 • Gate 0

Confirm scope, budget period, named owners, access, GitHub plan, approvers, and data-handling. Complete preflight IAM + quota + WIF checks. **No provisioning before Gate 0.**

Decision log signed • RACI confirmed • Security review scheduled
Preflight: GCP project, billing, IAM, quotas, WIF, branch protection validated

✓ **Exit Gate 0: All readiness checks green; otherwise timeline does not start.**

Phase 1 — Foundation & Security Week 1

Configure billing, APIs, IAM, federation, audit, budget alerts, and **two representative Cloud Run services**. Prove AI identity is non-privileged via negative IAM tests.

Budget alerts at 50/75/90/100% live • Audit logging cost-assessed
Negative IAM test evidence: AI identity cannot deploy

✓ **Exit Gate 1: IAM isolation demonstrated; cost alerts firing in test.**

Phase 2 — Monitoring & Intake Week 2

Deploy restricted Grafana CE, dashboards, SLOs, authenticated alert delivery, deduplication, and incident evidence schema.

Grafana authn/authz + network restriction + rate limits
Evidence schema: alert snapshot + log slice + deploy metadata + runbook ref

✓ **Exit Gate 2: Alert → incident → evidence bundle traceable end-to-end.**

Phase 3 — AI Diagnosis Week 3

Integrate Vertex AI Gemini with bounded evidence, approved runbooks, schema validation, redaction, action allowlist, and safe failure handling.

Structured output: diagnosis, citations, confidence, risk, rollback plan
Invalid / low-confidence output → policy reject

✓ **Exit Gate 3: ≥5 dry-run diagnoses scored; policy correctly rejects violations.**

Phase 4 — CI/CD & Approval Week 4

Integrate protected GitHub workflows, approval binding, expiry/rejection paths, idempotency, post-action health checks, and audit trail.

Approval bound to proposal hash; mutation → re-approval
Privileged creds only in protected job; bypass tests executed

✓ **Exit Gate 4: All 8 bypass tests pass; remediation enabled only now.**

Phase 5 — Scenario Evaluation Week 5

Run five fault scenarios and **at least 10 scored runs**; test negative paths, approval bypass, duplicate delivery, invalid model output, and service/workflow failures. Label live vs. simulated evidence.

5 scenarios: bad deploy, crash loop, quota exhaustion, disabled API, config drift
Every run links evidence → recommendation → decision → execution → outcome

✓ **Exit Gate 5: Scorecard complete; §9 acceptance criteria assessed.**

Phase 6 — Review & Clean-up Week 6 or earlier

Review results, spend, limitations, and risks. Live demo. Remove test resources and revoke temporary access unless retention is formally approved. Present **Proceed / Extend with Conditions / Stop** recommendation.

Spend reconciliation • Limitations register • Risk burn-down
Clean-up attestation or retention justification signed

✓ **Exit Gate 6: Final review signed; clean-up verified; GSK-separation attestation filed.**

■ **Schedule discipline**
Timeline starts *only after* Gate 0. If Gate 0 is not green, Week-1 does not start. Each phase has a single exit gate; a red gate stops downstream work. Daily stand-ups during fault-testing; weekly steering with sponsors.

8 FINANCIAL MODEL & BUDGET

USD 250 ceiling — unit economics, not just a total

■ **Budget period — Decision required before spend**
The table below is a **planning estimate, not a validated quotation**. Approval is *conditional* on confirming whether **USD 250 covers the entire 4–6 week pilot or a single monthly period**. Engineering effort is excluded; no new paid GitHub/software subscription is included; taxes, FX, and data-transfer must be checked.

Cost Category	Allocation	Share	Key Drivers & Validation Needed	Owner
Cloud Run — services & copilot runtime	USD 45	18%	Service count (2→20), requests, vCPU/memory, scale-to-zero, regions (2)	Platform
Grafana hosting & storage	USD 40	16%	Host size, uptime, disk, retention; CE license is free but hosting is not	Platform
Vertex AI — Gemini usage	USD 55	22%	Model, region, token volume (input+output), retries, runbook augmentation	Tech Lead
Logging, monitoring & audit storage	USD 30	12%	Log volume, audit categories enabled, retention; Data Access logs costed separately	Platform
Artifact storage, secrets & networking	USD 20	8%	Container registry, Secret Manager, egress; keep synthetic data small	Platform
Contingency (coordinator-gated)	USD 60	24%	Reserved for variance; use requires pilot coordinator review & log entry	Gupteswar
TOTAL CEILING	USD 250	100%	Subject to confirmation & pricing validation before Gate 0	



■ Cloud Run 18% ■ Grafana 16% ■ Vertex AI 22% ■ Logs 12% ■ Artifacts 8% ■ Contingency 24%

Spend controls
• Start with 2 services; expand only after measuring unit cost
• Daily spend review during fault testing; pause nonessential at 90%
• Budget alerts at 50/75/90/100% are *notify* — test operational stop separately
• Contingency draw requires coordinator entry + reason

What's excluded
• Engineering effort (QI staff time)
• New paid GitHub / SaaS subscriptions
• Taxes, currency conversion, material data-transfer
• Broad Data Access audit logging (validate cost before enabling)

Sensitivity — What moves the needle
• **Vertex AI tokens:** ±40% if evidence bounds loosen
• **Grafana uptime:** 24/7 vs. test-window-only = ~2×
• **Log retention:** 7d vs. 30d = +30–50%
• **Service count:** 20 ≠ 10× if scale-to-zero holds — but verify

9 SUCCESS MEASURES & ACCEPTANCE

From diagnostic accuracy to time-to-fix — all audited

Measure	Acceptance Criterion (pilot)	How Measured	Type
Diagnostic accuracy	≥90% correct primary diagnosis across ≥10 scored runs	Independent scoring vs. ground truth	Go/No-Go
Scenario coverage	All 5 scenarios exercised	Evidence bundle per scenario	Go/No-Go
Pipeline enforcement	Zero infra changes outside approved workflows	Workflow audit vs. resource log	Zero-tol
Human approval	100% of privileged remediations have pre-execution approval	Approval → execution correlation	Zero-tol
Restricted actions	Zero automated IAM / DB / failover / quota actions	Policy log + IAM audit	Zero-tol
Auditability	Every run links evidence → recommendation → decision → outcome	Trace completeness check	Go/No-Go
Duplicate protection	Repeated delivery of same incident → no duplicate remediation	Idempotency test	Go/No-Go
Time improvement	Median alert→approved-fix vs. manual baseline; target at kickoff	Timed runs; manual baseline Week 1	Directional
Budget	Spend within confirmed approved envelope	Daily cost report + reconciliation	Envelope
Isolation	No GSK resources, creds, or data used	IAM + project scope attestation	Zero-tol

■ **Measurement caveat — Read with rigor**

Ten runs provide an **initial pilot signal, not statistical evidence** of production reliability. The 90% threshold must be assessed *alongside* scenario coverage, failure evidence, and reviewer notes — not as a standalone pass/fail. A strong score with weak coverage is not a green light.

Leading indicators (weekly)
- Evidence completeness per incident (target: 100%)
- Policy reject rate & reasons (expect 10–20% on adversarial)
- Approval latency (p50 / p95)
- Idempotency block rate on duplicate injects

Lagging indicators (end of pilot)
- Scored diagnostic accuracy + inter-rater agreement
- Median alert→approved-fix delta vs. manual
- Zero-tolerance violations: count (must be 0)
- Spend vs. envelope; contingency draw reasons

10 RISKS, ASSUMPTIONS, ISSUES & DEPENDENCIES

RAID — what could derail us and what we'll do

1 • Incorrect AI recommendation → wrong remediation proposed

High — could mislead approver. Likelihood: Medium.

Impact: High **Likelihood: Med** Owner: Tech Lead

Mitigation: Evidence citations + confidence + approved runbooks required; deterministic allowlist rejects unsupported actions; human approval mandatory; post-action health checks verify outcome.

2 • Approval bypass — privileged change without valid approval

High — breaks trust model. Likelihood: Low if controls hold.

Impact: High **Likelihood: Low** Owner: CI/CD + Security

Mitigation: Separate identities, protected environment, proposal-hash binding, 8 adversarial bypass tests (blocking gate). Fail-closed on control unavailability.

3 • Sensitive data exposure via logs / prompts

High — compliance. Likelihood: Medium.

Impact: High **Likelihood: Med** Owner: Security

Mitigation: Synthetic / QI-approved data only; redaction before model call; least privilege; security review at Gate 0 and Gate 4.

4 • Prompt injection via telemetry (logs as attack vector)

Medium. Likelihood: Medium.

Impact: Med **Likelihood: Med** Owner: Tech Lead

Mitigation: Treat all telemetry as untrusted; never let prompt content alter policy or invoke tools; schema validation + allowlist as hard boundary.

5 • Cost overrun (token / log / uptime variance)

Medium. Likelihood: Medium.

Impact: Med **Likelihood: Med** Owner: Platform / Coordinator

Mitigation: Progressive scale (2 → ≤20), daily review, token/log budgets, alerts at 50/75/90/100%, pause at 90% pending forecast, tested stop procedure.

6 • Missing permissions / quotas — schedule slip

Medium. Likelihood: Medium.

Impact: Med **Likelihood: Med** Owner: Platform

Mitigation: Complete preflight before Week-1; quotas checked at Gate 0; no provisioning before green.

7 • Duplicate remediation on retried alerts

Medium. Likelihood: Medium.

Impact: Med **Likelihood: Med** Owner: Tech Lead

Mitigation: Idempotency keys, concurrency controls, and repeated-delivery testing (blocking gate).

8 • Fault testing impacts shared QI resources

Medium. Likelihood: Low.

Impact: Med **Likelihood: Low** Owner: Platform

Mitigation: Isolated services, bounded fault injection, documented recovery, agreed test windows, no shared prod touch.

Key Assumptions (to be validated at Gate 0)

A1. GitHub plan supports protected environments + required reviewers. *If not → compensating control or plan upgrade.*	**A2.** Vertex AI Gemini quotas and token pricing as estimated. *Validate region + model before Week-3.*
A3. Two reviewers available for approvals during test windows. *Confirm names at kickoff.*	**A4.** USD 250 period clarified (full pilot vs. monthly). *Blocking for spend authorization.*

11 GOVERNANCE & OPERATING MODEL

Who decides, who does, who reviews

Role	Proposed Owner	Accountability	RACI
Business Sponsors	Ken / Prithiviraj	Budget & pilot authorization; final Proceed/Stop	A
Pilot Coordinator	Gupteswar Mishra	Scope, dependencies, stakeholder reviews, final recommendation	R
Technical Lead	Akshay Saxena	Blueprint, build, integration, scoring & testing	R
Cloud / Platform	Assigned Engineer	GCP project, billing, IAM, quotas, infra, cost monitoring	R
CI/CD Owner	Assigned Engineer	Workflow integration, approval gates, deployment perms	R
Security Reviewer	Assigned Reviewer	Data handling, access controls, guardrails, bypass review	C
Remediation Approvers	Named Engineers (≥2)	Approve / reject each privileged proposal	A

* RACI highlights primary accountability per activity; detailed RACI matrix to be confirmed at kickoff. Named owners & approvers must be confirmed before Gate 0.

Operating cadence
- **Daily stand-up** (15 min) during build & fault-testing
- **Weekly steering** with sponsors + security (30 min) — gates, spend, risks
- **Gate reviews** at 0,1,2,3,4,5,6 — written sign-off
- **Incident review**: every scored run has a one-paragraph debrief

Controls & assurance
- Separation of duties: proposer ≠ approver ≠ executor
- All privileged actions traceable: evidence → proposal → approval → workflow → outcome
- Retention limits enforced; audit logs cost-assessed
- GSK-separation attestation filed at Gate 6

12 DECISIONS REQUESTED & NEXT STEPS

What we need from you — this week

#	Decision	Options	Required By
D1	Approve QI-only pilot scope; explicitly exclude GSK	Approve / Amend / Reject	Sponsors — before Gate 0
D2	Confirm USD 250 period (full 4–6 weeks vs. monthly)	Full pilot / Monthly / Revised ceiling	Sponsors + Finance — before Gate 0
D3	Confirm named owners, authorized approvers & escalation contacts	Names + backups	Coordinator — kickoff
D4	Confirm GitHub plan supports required approval controls	Confirm / Compensating control / Upgrade	CI/CD Owner — Gate 0
D5	Approve synthetic / QI-approved data use with Vertex AI + redaction	Approve / Amend data scope	Security + Sponsors — Gate 0
D6	Authorize provisioning only after readiness gate (Gate 0)	Authorize / Conditional	Sponsors — Gate 0 sign-off
D7	Require final review before any extension, prod rollout, or GSK proposal	Mandate separate approvals	Sponsors — standing

■ Recommendation (Tier-1 view)
Conditionally approve the pilot in principle. Begin with **2 services + recommendation-only** flow. Enable privileged remediation *only after* IAM isolation, approval enforcement, auditability, and all negative tests pass. Keep spend within the confirmed envelope and document every limitation. A successful QI pilot **does not** authorize GSK work.

■ Immediate next steps (5 days)
- **Day 1–2:** Decision log (D1–D7) + named RACI + approver list
- **Day 3:** Gate 0 preflight (IAM, WIF, quotas, GitHub protections)
- **Day 4:** Security review of data-handling & redaction
- **Day 5:** Gate 0 sign-off → authorize provisioning → Week 1 starts

✓ **What "conditional" means here**
Approval to *prepare* is not approval to *execute privileged changes*. The second authorization is gated by evidence — specifically, the bypass-test report at Gate 4. Sponsors retain a stop/pause right at any gate.

APPENDICES

Reference, assumptions & traceability

Appendix A — Reference Documentation

Topic	Reference
Workload Identity Federation — security best practices	Google Cloud — WIF best practices https://docs.cloud.google.com/iam/docs/best-practices-for-using-workload-identity-federation
Service accounts — security best practices	Google Cloud — Service accounts https://docs.cloud.google.com/iam/docs/best-practices-service-accounts
Deployment protection & approvals	GitHub Actions — Deployment protection https://docs.github.com/en/actions/how-tos/deploy/configure-and-manage-deployments/control-deployments
Billing budgets & alerts	Google Cloud — Budgets & alerts https://docs.cloud.google.com/billing/docs/how-to/budgets
SAP / Grafana / Vertex AI details	To be finalized during technical design & preflight validation (Gate 0–1)

Appendix B — Proposal Schema & Allowlist (illustrative)

Proposal record (required fields)
incident_id • target {service, region, revision} • action_type (allowlist enum) • exact_params • evidence_citations[] • confidence • risk • validation_result • rollback_plan • proposal_hash • idempotency_key

Approval is bound to **proposal_hash**. Any mutation → new hash → re-approval required.

Workflow spec (predefined)
• Single protected workflow: *.github/workflows/remediate.yml* on protected branch + environment
• Inputs validated against allowlist before execution
• Executor SA: narrow resource permissions, 15-min TTL
• Post-action: health check + audit record (actor, evidence, decision, outcome)

Appendix C — Cost Model Assumptions

Assumption	Value Used	Sensitivity
Cloud Run services	2 → 10–20, scale-to-zero, <1 vCPU avg	Linear if scale-to-zero fails
Grafana uptime	Test windows + limited 24/7; small VM	×2 if 24/7 on larger host
Vertex AI tokens	Bounded evidence (~4–8k in, ~1–2k out per incident), limited retries	±40% if bounds loosen
Log retention	7 days pilot; no broad Data Access logs	+30–50% at 30d or broad audit
Regions	2 (us-east1, us-central1) — no multi-region failover	Cost doubles if 3+ regions

Appendix D — Test Scenarios & Scoring Protocol

#	Scenario	Fault Injected	Expected Diagnosis	Scoring
S1	Bad deployment	Push faulty revision (500s spike)	Regression to revision N-1; evidence: error rate + deploy timestamp	Primary diagnosis correct?
S2	Startup failure / crash loop	Bad env var / missing secret	Startup probe failure; evidence: crash log + config diff	Primary diagnosis correct?
S3	Quota exhaustion	Throttle to quota limit	Quota metric + throttling log; no infra change	Allowlist respected?
S4	Disabled API	Disable dependent API	API disabled error; evidence: audit log + API state	Citations present?
S5	Configuration drift	Drift flag / traffic split error	Config diff + mismatch; bounded remediation	Params in scope?

Each scenario run is scored blind against ground truth. Live vs. simulated evidence is labelled. A run scores "correct" only if primary diagnosis matches and citations support it. Negative tests are scored separately as pass/fail on enforcement.

Appendix E — Document Control

Version	Date	Author	Changes	Status
v1.0	16 Oct 2026	Gupteswar Mishra	Initial working draft (7 pages)	Superseded
v2.0	16 Oct 2026	QI — Enhanced by Tier-1 Restructure	Full restructure: pyramid summary, zero-trust detail, stage gates, unit-economics, RAID, RACI, approval matrix, appendices; visual upgrade — substance preserved	Current — Awaiting approval

■ **How to use this document**
Executives: Read cover + §0 + §12. **Engineering & Security:** §4–§6. **Finance & Platform:** §8. **All reviewers:** §9–§11. Print via browser or PDF — this document is print-optimized to A4.

QUANTUM INTEGRATORS — INTERNAL PROPOSAL

AI SRE Copilot — Dev Pilot • QI-AI-SRE-2026-001 • v2.0 Enhanced

Confidential • QI Internal • GSK Excluded • 16 October 2026 • Prepared by Gupteswar Mishra & Akshay Saxena • Sponsors: Ken / Prithiviraj

This enhanced edition preserves all substance from v1.0 and elevates it for executive, audit, and client-readiness review. Original retained as *AI_SRE_Copilot_Dev_Pilot_Proposal_QI.pdf*.